MODULE 11 · DOMAIN 1 - ARCHITECTURE BUILT FOR THE CLOUD

Network Security and Global Traffic Routing

Inspect and filter at the right layer, then route users across Regions to the endpoint that should answer.

DOMAIN 1 of 5 EXAM WEIGHT 25% MODULE 11 of 52

admin@sthithapragna.com

Inspect at the right layer: packets, flows or requests. Each control sees only its own layer.

The controls and the layer each sees

CONTROL	LAYER	BEST AT
Security group	Instance, stateful	Allow rules, referencing other groups
Network ACL	Subnet, stateless	Explicit deny of address ranges
AWS Network Firewall	VPC traffic, stateful	IPS rules, domain filtering, managed
Gateway Load Balancer	Transparent appliances	Third-party firewalls at scale
AWS WAF	HTTP requests	Injection, bots, rate limits
AWS Shield	Network and application	DDoS; Advanced adds response team

ON THE EXAM

Security groups cannot deny. A specific address range to block is a network ACL or firewall rule.

Security group or network ACL?

SECURITY GROUP

Stateful, allow only

- Attached to an interface
- Return traffic allowed automatically
- Can reference other security groups
- No deny rules

NETWORK ACL

Stateless, ordered

- Applies to a whole subnet
- Return traffic needs its own rule
- Allow and deny, lowest number first
- Ephemeral ports must be opened

THE TIEBREAKER

Block a specific address range now: network ACL deny. Allow by role or tier: security group reference.

Network Firewall or Gateway Load Balancer?

AWS NETWORK FIREWALL

Managed, AWS-native

- Stateful and stateless rule groups
- Suricata-compatible IPS rules
- Domain allow and deny lists
- Attach directly to Transit Gateway

GATEWAY LOAD BALANCER

Your vendor's appliances

- Third-party firewalls you already license
- Transparent, using GENEVE encapsulation
- Scales and health-checks appliances
- GWLB endpoints steer traffic to it

THE TIEBREAKER

A named third-party firewall or existing licences means GWLB. Least operational overhead means Network Firewall.

Centralised inspection through a Transit Gateway

01

Spoke VPCs

Workloads route 0.0.0.0/0 to the Transit Gateway.

02

Inspection

Network Firewall, attached directly or in an inspection VPC.

03

Appliance mode

Keeps both directions of a flow in one AZ.

04

Egress VPC

Shared NAT gateways to the internet.

05

Return

Same path back, same firewall endpoint.

ON THE EXAM

One inspection point for many VPCs. Appliance mode stops return traffic landing on a different endpoint.

Centralised or distributed inspection?

CENTRALISED

One inspection point

- One rule set, one team
- Shared NAT and firewall cost
- Transit Gateway processing on every flow
- A shared dependency for all VPCs

DISTRIBUTED

Firewall in each VPC

- No hairpin through a hub
- Failure stays local
- Rules managed centrally with policies
- More endpoints to pay for

THE TIEBREAKER

Central control and shared egress favour centralised. Isolation of failure and no hub hop favour distributed.

Two VPC-wide guardrails, both new

- **VPC Block Public Access** (Nov 2024): block internet traffic, both ways or ingress only.
- It **supersedes route tables and security groups**; exclusions for chosen VPCs or subnets.
- **VPC Encryption Controls** (Nov 2025): monitor, then enforce, encryption in transit.
- Enforce mode blocks unencrypted resources; only **8 resource types** can be excluded.
- **Network Firewall and GWLB are not supported** in a VPC in enforce mode.

> ON THE EXAM
>
> Both can be deployed across an organisation with declarative policies. Both postdate older study material.

AWS WAF and Shield

- **WAF** attaches to CloudFront, ALB, API Gateway REST APIs, AppSync and Cognito.
- **Managed rule groups** for common exploits, SQL injection and known bad inputs.
- **Rate-based rules** and **Bot Control** limit abusive clients.
- **Shield Standard** is automatic and free for network-layer DDoS.
- **Shield Advanced**: response team, cost protection, health-based detection.

> ON THE EXAM
>
> Request-level attacks are WAF. Volumetric attacks are Shield. Cost protection for a DDoS bill is Shield Advanced.

VPC Flow Logs: what they can and cannot tell you

- **Accepted and rejected flows** by interface, subnet or VPC.
- **Custom fields** such as traffic-path, flow-direction and reject-reason.
- **encryption-status** field, with Encryption Controls, shows whether a flow was encrypted.
- **No packet contents.** Flow logs never show payloads or URLs.
- **Traffic Mirroring** copies packets when full inspection is needed.

> ON THE EXAM
>
> Flow logs answer who talked to whom and whether it was allowed. They never answer what was said.

Routing users across Regions is a choice between speed, location rules and failover.

Route 53 routing policies

POLICY	DECIDES BY	USE IT FOR
Latency	Lowest measured latency	Fastest Region for each user
Geolocation	Where the user is	Data residency, language, licensing
Geoproximity	Distance, with a bias	Shifting load between Regions
Failover	Health of the primary	Active-passive recovery
Weighted	Proportions you set	Gradual migration, canaries
IP-based	The client's network range	Routing known ISPs or offices

ON THE EXAM

Compliance means geolocation. Speed means latency. Geolocation needs a default record for unmatched users.

Global Accelerator or CloudFront?

GLOBAL ACCELERATOR

Network-level

- Two static anycast IP addresses
- TCP and UDP, any protocol
- Regional failover in seconds, no DNS caching
- No caching of content

CLOUDFRONT

HTTP-level

- Caches content at the edge
- HTTP and HTTPS only
- Edge functions and WAF
- Addresses change; use DNS names

THE TIEBREAKER

Static IPs, UDP or failover that ignores DNS caching means Global Accelerator. Cacheable web content means CloudFront.

Reading the scenario

WHEN THE QUESTION SAYS	IT IS TESTING
Block this address range now	Network ACL deny rule
Existing third-party firewall licences	Gateway Load Balancer
No VPC may ever accept internet traffic	VPC Block Public Access
Prove traffic in the VPC is encrypted	VPC Encryption Controls, monitor first
Static IPs, UDP, fast Regional failover	Global Accelerator
Users must be served in their own country	Route 53 geolocation

ON THE EXAM

Name the layer, then the control. Name the routing goal, then the policy.

> Meridian Freight's security team sees repeated connection attempts against a TCP service in a private subnet, all from one /24 range belonging to a known bad actor. The service is not HTTP.
>
> The range must be blocked for the whole subnet immediately.

What should the solutions architect do?

A Add a deny rule for the range to the instances' security group

B Add a low-numbered deny rule for the range to the subnet's network ACL

C Add the range to an AWS WAF IP set block rule

D Subscribe to AWS Shield Advanced

◆ PAUSE AND DECIDE

What should the solutions architect do?

A Security group deny

Security groups have no deny rules. This option cannot be configured.

B Network ACL deny

Evaluated first by number, applies to the whole subnet, takes effect at once.

C WAF IP set

WAF only sees HTTP requests on supported front ends. This is a raw TCP service.

D Shield Advanced

For DDoS. Connection attempts from one range need a simple block.

THE SIGNAL

A specific range to deny, at subnet scope, on a non-HTTP service. Only the network ACL fits.

> Meridian Freight has 50 VPCs attached to one Transit Gateway. Security requires that all outbound internet traffic is inspected and only allowed to an approved list of domains, under one rule set.
>
> The team wants the LEAST operational overhead and no third-party appliances.

Which design should the solutions architect recommend?

A. A NAT gateway in every VPC, with security groups restricting destinations

B. Squid proxy instances in a central VPC

C. AWS Network Firewall attached to the Transit Gateway, with a domain allow list, and a central egress VPC

D. Route 53 Resolver DNS Firewall in every VPC

◆ PAUSE AND DECIDE

Which design should the solutions architect recommend?

A NAT per VPC with security groups

Security groups match addresses, not domains, and there are 50 rule sets.

B Squid proxies

Works, but it is a fleet you patch, scale and keep available yourself.

C Network Firewall on the Transit Gateway

One managed rule set inspecting every VPC's egress, filtering by domain.

D DNS Firewall

Filters DNS lookups only. Traffic to a hard-coded IP address bypasses it.

THE SIGNAL

Domain filtering on the traffic itself, one rule set, managed. That combination is Network Firewall in a central path.

> Meridian Freight's security policy mandates a specific third-party next-generation firewall, for which the company holds enterprise licences and trained staff. Traffic between VPCs must pass through it.
>
> The firewall fleet must scale and survive the loss of an appliance without changing application routing.

How should the solutions architect insert the firewalls?

A. A Gateway Load Balancer in front of the appliance fleet, with Gateway Load Balancer endpoints in the traffic path

B. Replace the vendor firewall with AWS Network Firewall

C. A Network Load Balancer in front of the appliances

D. One large appliance instance with source and destination checks disabled

◆ PAUSE AND DECIDE

How should the solutions architect insert the firewalls?

A Gateway Load Balancer

Transparent, scales the fleet, health checks appliances, keeps routing unchanged.

B Network Firewall instead

Breaks the policy mandating the vendor, and wastes the licences.

C Network Load Balancer

Terminates at its own address, so the appliances do not see transparent traffic.

D One large instance

A single point of failure, with no scaling.

THE SIGNAL

A mandated vendor plus transparent, scalable insertion is the definition of Gateway Load Balancer.

> Meridian Freight's audit found internet-reachable instances in workload accounts, created by teams who attached internet gateways and opened security groups. Only one designated DMZ subnet in each account may receive internet traffic.
>
> The control must hold regardless of how teams configure routes or security groups, across all workload accounts.

What should the solutions architect implement?

A. An SCP that denies attaching internet gateways in workload accounts

B. An AWS Config rule that removes internet routes when found

C. Network ACLs on every subnet that deny inbound internet traffic

D. VPC Block Public Access in ingress-only mode, with an exclusion for the DMZ subnet, deployed by declarative policy

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A SCP denying internet gateways

Also blocks the DMZ and any outbound design, and cannot carve out one subnet.

B Config remediation

Acts after exposure, and teams can change it back.

C Network ACLs everywhere

Teams who can edit routes and groups can edit ACLs too.

D Block Public Access with an exclusion

Supersedes routes and security groups; the DMZ is a deliberate exception.

THE SIGNAL

Regardless of routes or security groups is Block Public Access's defining property.

A regulator requires Meridian Freight to prove that all traffic between workloads inside its payments VPC is encrypted in transit, and to prevent unencrypted resources being added later.

The VPC is two years old and runs a mix of instance generations.

What should the solutions architect do first?

A Turn on VPC Encryption Controls in enforce mode on the VPC

B Turn on VPC Encryption Controls in monitor mode, add encryption-status to new flow logs, and find blocking resources

C Require every application team to configure TLS

D Enable MACsec on the Direct Connect connection

◆ PAUSE AND DECIDE

What should the solutions architect do first?

A. Enforce mode now

Not allowed on an existing VPC. Monitor mode must come first.

B. Monitor mode, flow logs, find blockers

Produces evidence, lists old instances to upgrade, then enables enforce.

C. TLS everywhere

No proof across the VPC, and nothing prevents a new unencrypted resource.

D. MACsec

Encrypts a Direct Connect circuit, not traffic inside the VPC.

THE SIGNAL

An existing VPC goes to monitor mode first. Enforce mode follows once old resources are upgraded or excluded.

> Meridian Freight's truck telematics units send data over UDP to an ingestion service running in two Regions. The units' firmware holds fixed IP addresses that can only be changed by a site visit.
>
> If one Region fails, devices must reach the other within seconds.

What should the solutions architect use?

A Route 53 failover routing with health checks

B Amazon CloudFront with an origin group

C AWS Global Accelerator with an endpoint group in each Region

D A Network Load Balancer with Elastic IPs in each Region, both in the firmware

◆ PAUSE AND DECIDE

What should the solutions architect use?

A Route 53 failover

Devices use fixed IPs, not DNS, and DNS caching would slow failover anyway.

B CloudFront

HTTP only. UDP telemetry cannot pass through it.

C Global Accelerator

Two static anycast IPs for any protocol; shifts to the healthy Region in seconds.

D NLB IPs in firmware

Puts failover logic in every device, and any change needs a site visit.

THE SIGNAL

Fixed IPs, UDP and fast Regional failover. Every one of those is a Global Accelerator property.

What to carry out of this module

- **Security groups allow; network ACLs can deny.** Pick the layer that sees the threat.
- **Network Firewall** for managed inspection; **GWLB** for a mandated vendor.
- **Block Public Access** overrides routes and groups. **Encryption Controls**: monitor, then enforce.
- **Flow logs never contain payloads.** Traffic Mirroring for contents.
- **Global Accelerator** for static IPs, UDP and fast failover; **geolocation** for jurisdiction.

> ON THE EXAM
>
> Network Firewall and GWLB cannot run in a VPC with Encryption Controls in enforce mode.